

SOAL LATIHAN MANDIRI

Debian 13 — OS & Web Hardening Challenge

Nama peserta:

Tanggal:

Waktu rekomendasi: 4 jam

Tingkat: Menengah

Mode: CLI penuh

Sistem: Debian 13 pada VM latihan

1. Skenario

Kamu ditunjuk sebagai administrator keamanan untuk mengamankan sebuah server Debian 13 milik perusahaan fiktif **NusaLab**. Server ini menyediakan akses administrasi SSH, layanan transfer file FTP, website PHP melalui Nginx, dan database MariaDB.

Tim audit menemukan bahwa server pernah dipasang untuk keperluan pengujian secara cepat. Beberapa konfigurasi dibuat terlalu longgar, terdapat aturan sudo yang berbahaya, ada artefak service mencurigakan, dan database masih dapat menerima koneksi dari jaringan.

Kamu menerima akses awal sebagai user **guest**. Tugasmu adalah melakukan inventarisasi, mendapatkan akses administratif melalui jalur yang disediakan di skenario, memperbaiki seluruh kelemahan, dan membuktikan bahwa semua layanan tetap berjalan.

Server harus tetap memakai port default. Perubahan port dianggap pelanggaran karena sistem monitoring NusaLab sudah mengandalkan port standar.

Tujuan utama: bukan mematikan layanan, tetapi membuat layanan tetap berfungsi dengan akses minimum dan konfigurasi yang dapat dipertanggungjawabkan.

2. Informasi Awal

Gunakan VM Debian 13 yang baru atau snapshot yang dapat dikembalikan. Jangan mengerjakan soal ini pada server produksi.

Akun awal yang tersedia:

Akun	Password awal	Fungsi
guest	GuestStart!2026	Akun awal peserta
root	RootStart!2026	Jalur console atau su untuk administrasi lab
ubuntu	Jangan diubah	Akun pemeliharaan lab
anonymous	AnonStart!2026	Akun latihan untuk pengujian sudoers

Data layanan:

Layanan	Port wajib	Keterangan
SSH	22/tcp	Administrasi
HTTP	80/tcp	Website utama
HTTPS	443/tcp	Disiapkan untuk aturan firewall
FTP	21/tcp	Transfer file
MariaDB	3306/tcp	Wajib lokal saja

Password akhir yang ditetapkan oleh kebijakan latihan adalah:

```
4nT1pwn3dserv3r
```

Password tersebut hanya boleh digunakan di VM latihan. Pada sistem nyata, password yang ditulis di soal tidak boleh dipakai.

3. Aturan Pengerjaan

1. CLI diperbolehkan dan menjadi metode utama pengerjaan.
2. Semua perubahan konfigurasi harus dilakukan secara manual pada file konfigurasi layanan.
3. Dilarang memakai Ansible, script auto-hardening, Lynis sebagai alat perbaikan otomatis, atau script pihak ketiga yang mengubah sistem.

4. Script pemeriksa hanya boleh dipakai untuk membaca status setelah peserta memahami perubahan. Script tersebut tidak boleh melakukan perbaikan otomatis.
5. Jangan mengubah port default SSH, HTTP, HTTPS, FTP, atau MariaDB.
6. Jangan menghapus atau mengubah konfigurasi akun `ubuntu`.
7. Jangan mengubah konfigurasi WireGuard jika tersedia pada VM.
8. Jangan menghapus paket sistem secara sembarangan.
9. Sebelum mengubah file konfigurasi, buat backup.
10. Setelah setiap perubahan, lakukan validasi sintaks dan uji service.
11. Jangan menutup satu-satunya sesi administrasi sebelum koneksi baru berhasil diuji.
12. Setiap tindakan harus dicatat dalam lembar jawaban.

4. Aturan Tambahan NusaLab

Selain persyaratan hardening umum, terapkan aturan khusus berikut.

Aturan A — Prinsip akun

`guest` boleh digunakan untuk SSH, tetapi setelah hardening hanya boleh login menggunakan SSH key. `guest` tidak boleh menjadi anggota group `sudo`, `adm`, `docker`, atau group privileged lain yang tidak diperlukan.

Aturan B — Prinsip database

MariaDB hanya boleh menerima koneksi dari localhost. Aplikasi web boleh mengakses database melalui koneksi lokal, tetapi client dari jaringan tidak boleh mengakses port 3306.

Aturan C — Prinsip logging

Access log Nginx wajib aktif. Log autentikasi SSH dan log service tidak boleh dihapus. Peserta harus mampu menunjukkan bukti request HTTP dan percobaan login yang tercatat.

Aturan D — Prinsip file

File yang berisi password, key, atau konfigurasi rahasia tidak boleh dapat dibaca oleh user biasa. Permission harus dibatasi berdasarkan kebutuhan service.

Aturan E — Prinsip perubahan

Jika sebuah service tidak diperlukan untuk fungsi server, peserta boleh menonaktifkannya setelah mendokumentasikan alasan. Namun, pada soal ini SSH, Nginx, vsftpd, dan MariaDB

dianggap diperlukan sehingga tidak boleh dimatikan untuk memperoleh nilai.

5. Tahap 0 — Login dan Baseline

Mulai dari login sebagai `guest` .

Buktikan identitas awal dengan mencatat output:

```
whoami  
id  
hostname  
pwd
```

Periksa apakah guest mempunyai hak administratif:

```
sudo -l
```

Jika diperlukan untuk masuk ke tahap administrasi, gunakan jalur root yang disediakan skenario:

```
su -
```

Setelah menjadi root, catat baseline:

```
ss -tulpn  
systemctl --failed  
systemctl --type=service --state=running  
ps auxf
```

Inventarisasi akun:

```
getent passwd root ubuntu guest anonymous
id root
id ubuntu
id guest
id anonymous
```

Inventarisasi SUID:

```
find / -xdev -type f -perm -4000 -ls 2>/dev/null
```

Cari cron, timer, dan service yang tidak dikenal:

```
systemctl list-timers --all
find /etc/cron* /var/spool/cron -type f -ls 2>/dev/null
systemctl list-unit-files --state=enabled
```

Bukti yang dikumpulkan: output baseline, daftar port, daftar service gagal, daftar SUID, dan daftar akun.

6. Tahap 1 — Management User

Kerjakan dari root setelah mencatat baseline.

1. Ubah password Linux `root` , `guest` , dan `anonymous` menjadi password kebijakan latihan.
2. Pastikan user `guest` tetap tersedia.
3. Pastikan `guest` tidak berada dalam group `sudo` , `adm` , `docker` , atau group privileged lain yang tidak diperlukan.
4. Pastikan shell dan home directory akun tidak berubah secara tidak perlu.
5. Periksa status password setelah perubahan.
6. Catat perbedaan antara password root Linux dan password root MariaDB.

Bukti yang dikumpulkan:

```
passwd -S root
passwd -S guest
passwd -S anonymous
groups guest
```

7. Tahap 2 — SSH Hardening

Perbaiki konfigurasi SSH dengan persyaratan berikut.

1. Root tidak boleh login langsung melalui SSH.
2. Hanya `ubuntu` dan `guest` yang boleh tercantum sebagai user SSH yang diizinkan.
3. `guest` tidak boleh menggunakan password untuk SSH.
4. `guest` hanya boleh menggunakan public key.
5. Port SSH tetap 22.
6. Konfigurasi harus lolos pemeriksaan sintaks.
7. Service SSH harus tetap aktif.

Uji minimal:

- Login `root` harus gagal.
- Login `guest` dengan password harus gagal.
- Login `guest` dengan key yang sah harus berhasil.
- Login `ubuntu` harus tetap tersedia.

Bukti: potongan konfigurasi aman, output validasi, status service, dan hasil uji koneksi.

8. Tahap 3 — FTP/vsftpd

Perbaiki vsftpd dengan sasaran berikut.

1. Anonymous login harus dinonaktifkan.
2. Port FTP tetap 21.
3. Service tetap aktif.
4. Login anonymous harus gagal.

5. Jika akses lokal tetap diperlukan, jangan merusak konfigurasi user lokal.

Bukti: parameter `anonymous_enable`, status service, listener port 21, dan hasil uji anonymous login.

9. Tahap 4 — Nginx

Perbaiki web server dengan persyaratan berikut.

1. Nomor versi Nginx tidak boleh terlihat pada response HTTP.
2. Access log wajib diarahkan ke `/var/log/nginx/access.log`.
3. Port HTTP tetap 80.
4. Konfigurasi harus lolos `nginx -t`.
5. Website tetap dapat diakses.

Buat request pengujian menggunakan `curl`, kemudian tunjukkan bahwa request tercatat pada access log.

Bukti: output header HTTP, output access log, hasil `nginx -t`, dan status service.

10. Tahap 5 — PHP Secure Coding

Audit aplikasi PHP pada document root. Perbaiki kerentanan berikut tanpa menghapus fungsi utama website.

1. Input `id` tidak boleh langsung digabung ke SQL query.
2. Output dari input pengguna harus di-escape sebelum ditampilkan sebagai HTML.
3. Parameter `page` tidak boleh menentukan path file secara bebas.
4. Input pengguna tidak boleh diteruskan ke `system`, `exec`, `shell_exec`, `passthru`, `popen`, atau `eval`.
5. Error detail tidak boleh ditampilkan kepada client.
6. Error harus dicatat ke log server.
7. Informasi versi PHP tidak perlu ditampilkan pada response.

Pengujian harus mencakup request normal dan request input yang sebelumnya berbahaya. Tujuan pengujian adalah membuktikan input ditolak atau diperlakukan sebagai data, bukan mengeksekusi payload berbahaya.

Bukti: perubahan kode, hasil lint PHP, hasil request normal, dan konfigurasi error PHP.

11. Tahap 6 — UFW

Konfigurasi firewall dengan aturan berikut.

1. Default incoming adalah deny.
2. Default outgoing adalah allow.
3. Izinkan hanya TCP 22, 21, 80, dan 443 sesuai kebutuhan soal.
4. Jangan membuka TCP 3306 untuk jaringan luar.
5. Aktifkan UFW.
6. SSH harus sudah diizinkan sebelum firewall diaktifkan.

Bukti: `ufw status verbose` , daftar rule, dan hasil pengujian port dari client.

12. Tahap 7 — Sudoers

Cari aturan sudo yang berbahaya.

1. Temukan aturan yang memberi user `anonymous` akses root tanpa password.
2. Hapus atau perbaiki aturan tersebut menggunakan `visudo` .
3. Pastikan tidak ada aturan `anonymous ... NOPASSWD: ALL` .
4. Validasi seluruh file sudoers.
5. Jangan membuat aturan sudo baru yang lebih luas dari kebutuhan.

Bukti: hasil pencarian sebelum, perubahan, dan `visudo -c` setelah perubahan.

13. Tahap 8 — SUID dan SGID

Lakukan analisis, bukan penghapusan membabi buta.

1. Buat daftar binary SUID dan SGID.
2. Identifikasi file yang berasal dari paket Debian.
3. Identifikasi file tambahan yang tidak dikenal.
4. Periksa owner, mode, hash, dan lokasi file.
5. Hapus bit SUID dari artefak latihan yang tidak diperlukan.
6. Jangan merusak binary sistem yang diperlukan.

Bukti: daftar sebelum/sesudah dan alasan setiap perubahan.

14. Tahap 9 — Backdoor dan Persistence

Cari mekanisme yang dapat menjalankan program secara otomatis.

1. Periksa service systemd.
2. Periksa timer.
3. Periksa cron system dan cron user.
4. Periksa proses berjalan dan port listening.
5. Periksa file mencurigakan di `/tmp` , `/var/tmp` , `/dev/shm` , `/opt` , dan document root.
6. Identifikasi service atau script latihan yang berfungsi sebagai backdoor.
7. Simpan catatan bukti sebelum menghapusnya.
8. Disable dan hapus artefak yang telah dipastikan berbahaya.
9. Reload systemd dan pastikan proses/port tidak muncul kembali.

Bukti: path artefak, service unit, tindakan yang dilakukan, dan pemeriksaan ulang.

15. Tahap 10 — Permission File Kritis

Periksa permission file berikut:

- `/etc/shadow`
- `/etc/gshadow`
- `/etc/ssh/sshd_config`
- `/etc/sudoers`
- `/etc/vsftpd.conf`
- Konfigurasi MariaDB
- File rahasia aplikasi
- Private key jika tersedia

Sasaran:

1. Owner file kritis adalah root jika file memang milik root.
2. User biasa tidak dapat membaca file rahasia.

3. Service tetap dapat membaca file yang memang diperlukan.
4. Tidak ada file konfigurasi sensitif yang writable oleh semua user.

Gunakan `stat`, `ls -l`, dan uji akses sebagai user biasa. Jangan menerapkan satu mode permission ke seluruh `/etc`.

16. Tahap 11 — MariaDB

1. Ubah password root MariaDB sesuai password kebijakan latihan.
2. Bedakan root Linux dan root database.
3. Periksa akun database dan host asalnya.
4. Set `bind-address` ke `127.0.0.1`.
5. Pastikan tidak ada konfigurasi lain yang menimpa pengaturan tersebut.
6. Restart MariaDB dan pastikan service aktif.
7. Buktikan listener berada di loopback.
8. Uji koneksi lokal.
9. Pastikan koneksi dari alamat jaringan luar tidak diterima.
10. Jangan membuka port 3306 pada UFW.

Bukti: query user database, konfigurasi, status service, dan `ss -ltnp`.

17. Tahap 12 — Audit Akhir

Jalankan pemeriksaan berikut:

```
systemctl --failed
systemctl is-active ssh vsftpd nginx mariadb
ss -tulpn
ufw status verbose
sshd -t
nginx -t
visudo -c
```

Lakukan pengujian fungsional:

- SSH user yang diizinkan.
- Penolakan SSH root.
- Penolakan password SSH guest.
- Penolakan anonymous FTP.
- HTTP normal dan access log.
- PHP tidak memproses input sebagai command.
- Database lokal dapat diakses aplikasi.
- Port 3306 tidak terbuka ke jaringan.

18. Sistem Penilaian

Total nilai adalah 100.

Komponen	Nilai
Baseline dan dokumentasi	5
Management user	8
SSH	15
FTP	7
Nginx	10
PHP	15
UFW	10
Sudoers	8
SUID/SGID	7
Backdoor/persistence	8
Permission file kritis	4
MariaDB	10
Audit akhir dan bukti	3
Total	100

Interpretasi nilai:

Nilai	Interpretasi
90–100	Sangat baik; konfigurasi dan bukti lengkap
75–89	Baik; masih ada kekurangan minor
60–74	Cukup; beberapa kontrol penting belum selesai
1–59	Perlu perbaikan besar
0	Baseline belum dikerjakan atau sistem tidak dapat diuji

19. Penalti

Pelanggaran	Penalti
Mengubah port default	-20
Membuka MariaDB ke jaringan	-15
Mengunci akses administrasi tanpa jalur pemulihan	-15
Menghapus binary sistem tanpa analisis	-10
Mengubah konfigurasi akun <code>ubuntu</code>	-10
Mengubah WireGuard	-10
Menggunakan auto-hardening tanpa memahami perubahan	-20
Mematikan service wajib untuk mengejar skor	-10

Nilai akhir tidak boleh kurang dari 0.

20. Format Jawaban Peserta

Untuk setiap bagian, tuliskan lima hal berikut.

1. **Temuan:** apa kondisi awal yang tidak aman?
2. **Risiko:** mengapa kondisi tersebut berbahaya?
3. **Perubahan:** file dan parameter apa yang diubah?
4. **Pengujian:** perintah apa yang membuktikan service tetap berjalan?
5. **Hasil:** bukti output dan status akhir.

Gunakan tabel berikut:

Tahap	Temuan	Risiko	Perubahan	Pengujian	Hasil
User					
SSH					
FTP					
Nginx					
PHP					
UFW					
Sudoers/SUID					
Backdoor					
Permission					
MariaDB					

21. Kriteria Lulus

Peserta dinyatakan lulus jika memperoleh minimal 75, tidak melakukan pelanggaran kritis, semua service wajib tetap berjalan, dan bukti pengujian dapat diverifikasi. Nilai tinggi tanpa bukti tidak dianggap lengkap.

22. Catatan untuk Instruktur

Skenario ini sebaiknya dijalankan pada VM terisolasi dengan snapshot. Instruktur dapat menambahkan file web shell latihan, cron job latihan, systemd unit latihan, aturan sudoers berbahaya, file rahasia, dan binary SUID non-sistem. Setiap artefak harus diberi penanda internal agar tidak tertukar dengan file Debian asli.

Instruktur sebaiknya menyediakan progress checker terpisah yang hanya membaca kondisi. Checker harus membuat baseline sebelum peserta mulai dan tidak boleh mengganggu konfigurasi bawaan yang sudah aman sebagai hasil peserta.

Penutup

Soal ini dirancang agar peserta belajar alur kerja administrator keamanan, bukan sekadar menyalin perintah. Peserta dimulai sebagai `guest`, memahami batas hak akses, berpindah ke jalur administratif yang sah, mencatat kondisi awal, mengamankan layanan satu per satu, dan membuktikan hasilnya melalui pengujian. Keberhasilan ditentukan oleh keamanan, ketersediaan layanan, dan kualitas dokumentasi.